

FORENSIC INVESTIGATION REPORT

Case ID: SSH-BRUTE-2025-11

1. Executive Summary

This report documents a simulated **SSH brute-force attack** followed by a **file exfiltration event** conducted within an isolated lab environment.

The objective was to capture, analyze, and document the sequence of unauthorized SSH login attempts, one successful authentication, and a subsequent file transfer via `scp`.

All activity was captured using `tcpdump`, and correlated with host logs (`journalctl`) to demonstrate a complete forensic workflow.

2. Objective

To generate and analyze digital evidence (PCAPs, logs, and system artifacts) demonstrating:

- Multiple failed SSH authentication attempts.
- One successful SSH login using a weak test password.
- A file exfiltration event via `scp` or `rsync`.
- Extraction of Indicators of Compromise (IOCs): Source IPs, timestamps, account name, file name, and file size.

3. Environment Setup

Role	Operating System	IP Address	Description	
Attacker	Kali Linux	172.16.223.193	Initiated brute-force SSH attempts and file transfer	
Victim / Target	Parrot OS	172.16.209.85	Hosted SSH service and secret file for exfiltration	

SSH Configuration:

- PasswordAuthentication: Enabled
- LogLevel: VERBOSE
- SSH Port: 22

File Created on Target:

/home/testuser/secret.txt

Size: 27 bytes

4. Tools Used

Tool	Purpose
OpenSSH	SSH client/server setup
tcpdump	Capture SSH network traffic
tshark	Command-line packet analysis
sshpas	Automate SSH login attempts
rsync / scp	Simulate data exfiltration
journalctl	Extract SSH authentication logs

5. Evidence Collected

Evidence Type	Path / Command	Size	Notes	
Network Capture	/tmp/artifacts/ssh_lab.pcap	131 KB	Captured SSH traffic	
SSH Logs	/tmp/artifacts/auth.log	13 KB	Contains failed/success logins	
Full Journal	/tmp/artifacts/auth_full.log	1.6 MB	Full SSH service log	
Login History	/tmp/artifacts/last.log	1.4 KB	Recent login data	
Failed Login List	/tmp/artifacts/lastb.log	3.6 KB	Failed login attempts	
File Metadata	/tmp/artifacts/secret_stat.txt	488 B	Details of exfiltrated file	
Hashes	.sha256 files	—	Evidence integrity verification	

File Hashes (SHA256):

ssh_lab.pcap = <generated hash, 94 bytes file>

auth.log = <generated hash, 90 bytes file>

6. Analysis

6.1 PCAP Analysis (tshark – TCP Conversations)

Top TCP flows captured on port 22 indicate multiple SSH sessions, including several short attempts and one larger sustained session (file transfer)

Source (Attacker)	Destination (Victim)	Bytes Sent	Bytes Received	Total	Duration (s)
172.16.223.193:39132	172.16.209.85:22	6,561	6,129	12 KB	1.48
172.16.223.193:43014	172.16.209.85:22	6,569	5,993	12 KB	1.46
172.16.223.193:35304	172.16.209.85:22	5,477	5,161	10 KB	1.61

(Several others with ~8 KB total traffic, 3–4s duration)

➡ Interpretation:

Short-lived TCP sessions (3–4s) correspond to **failed password attempts**.

The longer sessions (~12 KB total) indicate **successful login + file transfer activity**.

6.2 TCP Flag Analysis (Connection Attempts)

```
tshark -Y "tcp.flags.syn==1 || tcp.flags.reset==1 || tcp.flags.fin==1"
```

Multiple SYN packets followed by quick FIN/RST responses confirm **many short unsuccessful SSH connections**, consistent with a brute-force pattern

Time (IST)	Source	Destination	Flag	Description
08:22:45	172.16.223.193	172.16.209.85	0x0002	SYN – new connection
08:22:45	172.16.209.85	172.16.223.193	0x0012	SYN+ACK
08:23:53	172.16.223.193	172.16.209.85	0x0011	FIN+ACK – connection close
08:27:55	172.16.223.193	172.16.209.85	0x0002	SYN – final connection (likely successful)
08:27:56	172.16.223.193	172.16.209.85	0x0011	FIN+ACK – completion (file transfer end)

➡ **Interpretation:**

A pattern of repeated short SYN-FIN connections followed by one final long connection strongly suggests brute-force login followed by exfiltration.

6.3 Host Log Analysis

`journalctl` output (filtered with “Failed password” / “Accepted password”) shows:

- **Multiple “Failed password for testuser”** attempts within the same minute window.
- One **“Accepted password for testuser”** entry (successful login).

Example entries (filtered):

2025-11-12T08:23:30 IST – Failed password for testuser from 172.16.223.193
2025-11-12T08:27:07 IST – Accepted password for testuser from 172.16.223.193

➡ **Interpretation:**

The logs align with network evidence — repeated failed attempts followed by one successful login.

6.4 File Metadata

```
stat /home/testuser/secret.txt
```

Size: 27 bytes
Modify: 2025-11-12 08:13:46 IST
Owner: testuser:testuser
Permissions: -rw-r--r--

This small plaintext file was the target of the simulated **file exfiltration**.
File transfer occurred within ~10 minutes after its modification.

6.5 Timeline (Correlated Events)

Timestamp (IST)	Source → Destination	Event Description
08:22:45	Kali → Parrot	First SSH connection attempt (SYN)
08:23:30–08:25:53	Kali → Parrot	Multiple short SSH attempts (failed passwords)
08:27:07	Kali → Parrot	Successful SSH login (Accepted password)
08:27:55	Kali → Parrot	SCP file transfer session begins
08:27:56	Kali → Parrot	File transfer complete (stolen_secret.txt)

7. Indicators of Compromise (IOCs)

IOC Type	Value
Attacker IP	172.16.223.193
Victim IP	172.16.209.85
Username	testuser
File Exfiltrated	/home/testuser/secret.txt
File Size	27 bytes
SSH Port	22
Authentication Type	Password (weak)

8. Findings

The PCAP clearly captures multiple SSH connections from the attacker to the victim.

System logs confirm repeated failed logins followed by one success.

The successful session coincides with a TCP conversation showing higher data transfer — confirming **file exfiltration**.

All evidence is time-aligned (IST) and integrity-verified using SHA256 hashes.

9. Conclusion

This simulation successfully demonstrated:

- The **pattern of a brute-force SSH attack**,
- Followed by **unauthorized access** and **data exfiltration** via SCP.

Both **network-level** (PCAP) and **host-level** (auth logs) evidence align chronologically and technically, validating the attack chain.

10. Recommendations / Mitigation

To prevent such incidents in real-world environments:

1. **Disable password-based SSH logins**; enforce key-based authentication.
2. **Implement fail2ban** or equivalent intrusion prevention tools.
3. **Use strong passwords** and rotate credentials periodically.
4. **Restrict SSH access** using firewall rules or allowlisting.
5. **Enable system logging and remote log backups** for forensic correlation.
6. **Conduct regular penetration testing** to validate configurations.

11. Evidence Integrity Summary

File: **ssh_lab.pcap** and **auth.log**